

viewstalker

viewstalker - isclayton, GitHub.

- Published: date not stated
- Original: <https://github.com/isclayton/viewstalker>
- Preserved from: <https://github.com/isclayton/viewstalker> (preserved-copy) on 2026-08-04
- Repository commit: 313e553bd635a07d5a128ac60eeca422f73bf39a
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Repository reading copy: selected documentation at the recorded commit. Source code is never checked out, built or run.

- Repository: <https://github.com/isclayton/viewstalker>
- Commit: 313e553bd635a07d5a128ac60eeca422f73bf39a
- Documents preserved: 2

LICENSE.txt

Blob c0681fbf899f, 1111 bytes, at commit 313e553bd635.

The MIT License (MIT)

Copyright (c) NotSoSecure Global Services Limited

Permission is hereby granted, free of charge, to any person obtaining a copy of this software and associated documentation files (the "Software"), to deal in the Software without restriction, including without limitation the rights to use, copy, modify, merge, publish, distribute, sublicense, and/or sell copies of the Software, and to permit persons to whom the Software is furnished to do so, subject to the following conditions:

The above copyright notice and this permission notice shall be included in all copies or substantial portions of the Software.

THE SOFTWARE IS PROVIDED "AS IS", WITHOUT WARRANTY OF ANY KIND, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO THE WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE AND NONINFRINGEMENT. IN NO EVENT SHALL THE

AUTHORS OR COPYRIGHT HOLDERS BE LIABLE FOR ANY CLAIM, DAMAGES OR OTHER LIABILITY, WHETHER IN AN ACTION OF CONTRACT, TORT OR OTHERWISE, ARISING FROM, OUT OF OR IN CONNECTION WITH THE SOFTWARE OR THE USE OR OTHER DEALINGS IN THE SOFTWARE.

README.md

Blob c0173755b33a , 4228 bytes, at commit 313e553bd635 .

Viewstalker

A tool for identifying and exploiting vulnerable view state implementations in ASP.NET

Background

View states are used in ASP.NET applications to preserve page and control values between round trips. View states may or may not be encrypted, and may or may not be signed using the machine authentication code (MAC) validation mechanism. Where MAC validation is implemented, deserialization on the backend is performed by [System.Web.UI.LosFormatter](#) after [ObjectStateFormatter](#) has successfully verified the integrity of a given view state. [System.Web.UI.LosFormatter](#) does not (and cannot) perform deserialization securely. As a result, an attacker with knowledge of an application's validation key (defined in `machine.config` or `web.config`) can achieve remote code execution on a vulnerable target by supplying a malicious gadget chain, like those generated by [ysoserial.net](#).

Despite the relative ease of exploitation, to my knowledge no utility exists to easily check large numbers of hosts for vulnerable implementations, and no utility at all exists to check hosts from Linux or OSX. It's not suprising therefore that this vulnerability remains fairly common in the wild. To address this I'm providing ViewStalker. Enjoy :)

```
usage: viewstalker [-h|--help] [-l|--hosts <file>] [-M|--mac <file>]
                  [-a|--address "<value>"] [-v|--viewstate "<value>"]
                  [-m|--modifier "<value>"] [-k|--no-check-cert]
                  [-d|--debug] [--stdin]
```

A tool **for** identifying vulnerable ASP.NET viewstates

Arguments:

-h	--help	Print help information
-l	--hosts	Path to file with list of hosts to check, one per line
-M	--mac	machine keys file from blacklist3r
-a	--address	Single host to check
-v	--viewstate	b64 encoded __VIEWSTATE
-m	--modifier	modifier
-k	--no-check-cert	Disable TLS verification for use with mitm proxy etc
-d	--debug	Enable debug logging
-o	--output	Output file for positive results (JSON format)
	--stdin	Read hosts from stdin (piped input)

Examples:

Single host

```
./viewstalker -a example.com -M keys.txt
```

Multiple hosts **from** file

```
./viewstalker -l hosts.txt -M keys.txt
```

Piped input

```
cat hosts.txt | ./viewstalker -M keys.txt
```

With debug logging

```
./viewstalker -d -l hosts.txt -M keys.txt
```

Save results to file

```
./viewstalker -l hosts.txt -M keys.txt -o results.json
```

Piped input

```
http -silent -l hosts.txt -mc 200 | ./viewstalker -M merged_machine_keys.txt -o
results.json
```

```
[~]/ViewStalker]
$ ./viewstalker -a http://[redacted] -M MachineKeys2.txt
Trying
http://[redacted]
KEY FOUND!!!
Host: http://[redacted]
Validation Key: EF2E74808CE348777A34240B31C9B64FAC633CB3F493FE6370AF83CD789C9253C2CF8B88908A14C28AF5D9D09EB51BFD7F85C
5F72F11A7A71D0D91377F34B709,9D1CCF73B5DC24A2E042E99F4A11D83CD132CBBB7DC4A962
```

TODO:

- [x] initial target handling and parsing
- [x] recreate blacklist3r functionality for bruting keys
- [x] Multi-host scanning
- [x] Concurrent processing and performance optimization
- [x] Debug logging and output formatting
- [] automatic payload generation and exploitation
- [] Support for JSF view states

Disclaimer

This software is intended to help security professionals find and remediate vulnerabilities stemming from reuse of publicly known machine keys. It is not intended to be used to attack systems except where explicitly authorized. Project maintainers are not responsible or liable for misuse of the software. Use responsibly.

In its current form, this software is not related with any company or organization, including those associated with the project maintainer or contributors.

Acknowledgement

[NotSoSecure Soroush Dalili](#)

Bug Bounty

I hack on the Synack platform. If you like the utility, please consider adding me as a contributor to your vulnerability reports ;)

<https://acropolis.synack.com/inductees/iek/>